

PASSIVE VULNERABILITY ASSESSMENT OF ALTORO MUTUAL

Security Assessment & Risk Analysis Report

Submitted as Part of the

Future Interns Cyber Security Internship Program

Prepared By:

Safal Kumar Singh

Internship Domain: Cyber Security

Organization: Future Interns

Assessment Type: Passive / Non-Intrusive Vulnerability Assessment

Target Application: Altoro Mutual (<http://demo.testfire.net>)

Report Date: May 2026

TABLE OF CONTENTS

1. Executive Summary
2. Scope of Assessment
3. Assessment Methodology
4. Reconnaissance and Service Enumeration
5. Security Header Analysis
6. SSL/TLS Configuration Review
7. OWASP ZAP Passive Analysis
8. Detailed Vulnerability Findings
9. Risk Classification Matrix
10. Security Posture Assessment
11. Remediation Recommendations
12. Conclusion
13. Disclaimer

1. EXECUTIVE SUMMARY

This report presents the findings of a passive and non-intrusive vulnerability assessment conducted on the intentionally vulnerable web application **Altoro Mutual** hosted at <http://demo.testfire.net>.

The assessment was performed as part of the **Future Interns Cyber Security Internship Program** and strictly adhered to ethical and educational security testing practices. No exploitation attempts or destructive testing methods were employed during the assessment.

The primary objective was to identify publicly observable security weaknesses and misconfigurations using passive reconnaissance and vulnerability assessment techniques.

Assessment Objectives

- Identify observable security weaknesses using passive techniques.
- Analyse HTTP security headers and web application responses.
- Review SSL/TLS configurations and encryption support.
- Perform reconnaissance and service enumeration.
- Provide remediation recommendations aligned with industry best practices and OWASP guidelines.

Tools Utilized

Tool	Purpose
Nmap	Port and service enumeration
OWASP ZAP	Passive vulnerability scanning
cURL	HTTP header inspection
SSLScan	SSL/TLS configuration analysis
Browser Developer Tools	Client-side analysis

2. SCOPE OF ASSESSMENT

Assessment Details

Parameter	Description
Target URL	http://demo.testfire.net
Assessment Type	Passive Vulnerability Assessment
Application Type	Deliberately Vulnerable Banking Application
Assessment Period	May 2026

In-Scope Activities

- HTTP and HTTPS traffic observation
- Security header analysis
- SSL/TLS configuration review
- Passive vulnerability scanning using OWASP ZAP
- Network reconnaissance and service discovery

Out-of-Scope Activities

- Exploitation attempts
- SQL Injection testing
- Authentication bypass attacks
- Brute-force testing
- Denial-of-Service (DoS) attacks
- Any destructive security testing

3. ASSESSMENT METHODOLOGY

A structured security assessment methodology was adopted to ensure comprehensive yet non-intrusive analysis.

Phase 1: Reconnaissance

Initial reconnaissance activities were performed to identify publicly accessible services, application endpoints, and externally visible attack surfaces.

Phase 2: Service Enumeration

Network reconnaissance was conducted using Nmap to identify open ports and discover running services.

Phase 3: Passive Web Application Analysis

OWASP ZAP was configured in passive scan mode to observe HTTP responses and identify security misconfigurations without actively attacking the application.

Phase 4: HTTP Header Inspection

HTTP response headers were inspected using cURL and OWASP ZAP to evaluate the implementation of standard security controls.

Phase 5: SSL/TLS Configuration Review

SSLScan was utilized to examine supported protocols, encryption standards, and cipher suite configurations.

4. RECONNAISSANCE AND SERVICE ENUMERATION

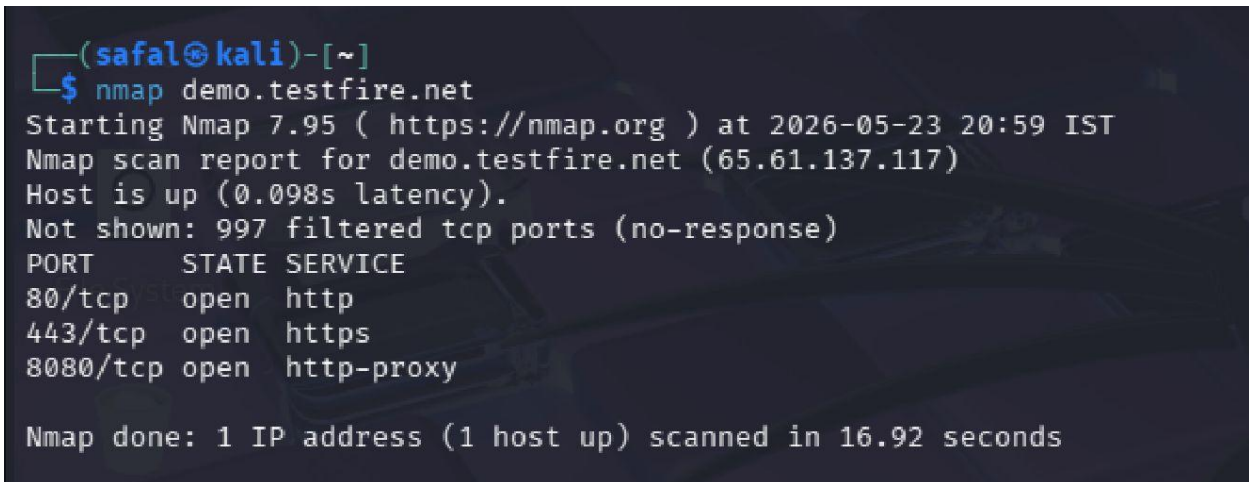
4.1 Nmap Scan Results

The Nmap scan identified the following publicly exposed services:

Port Protocol State Observation

80	HTTP	Open Web application accessible
443	HTTPS	Open Secure HTTPS service available

Figure 4.1: Nmap Scan Results

A screenshot of a terminal window with a dark background. The prompt is (safal@kali)-[~]. The user has entered the command \$ nmap demo.testfire.net. The output shows the Nmap version (7.95), the target IP (65.61.137.117), and the scan results for ports 80, 443, and 8080. The services identified are http, https, and http-proxy.

```
(safal@kali)-[~]  
$ nmap demo.testfire.net  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-23 20:59 IST  
Nmap scan report for demo.testfire.net (65.61.137.117)  
Host is up (0.098s latency).  
Not shown: 997 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
80/tcp    open  http  
443/tcp    open  https  
8080/tcp   open  http-proxy  
  
Nmap done: 1 IP address (1 host up) scanned in 16.92 seconds
```

4.2 Public Attack Surface Observations

The following observations were made during reconnaissance:

- Both HTTP and HTTPS services are publicly accessible.
- Banking-related functionality is accessible without authentication.
- Application responses reveal information regarding underlying technologies and system structure.

5. SECURITY HEADER ANALYSIS

HTTP response headers were inspected using cURL and OWASP ZAP to evaluate security hardening mechanisms.

Security Header Findings

Security Header	Status	Observation
Content-Security-Policy	Missing	Increased exposure to XSS attacks
X-Frame-Options	Missing	Potential clickjacking risk
Strict-Transport-Security	Missing	Susceptible to downgrade attacks
X-Content-Type-Options	Missing	MIME sniffing possible
Server Header	Present	Information disclosure observed

Figure 5.1: HTTP Header Analysis

```
(safal@kali)-[~]
$ curl -I http:// demo.testfire.net
curl: (3) URL rejected: No host part in the URL
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=22F662541337A6D4837EE979E136D3AD; Path=/; HttpOnly
Content-Type: text/html; charset=ISO-8859-1
Transfer-Encoding: chunked
Date: Sat, 23 May 2026 15:25:45 GMT
```

6. SSL/TLS CONFIGURATION REVIEW

SSLScan was used to assess protocol support and encryption configurations.

Protocol Assessment

Protocol Status

TLS 1.2 Enabled

TLS 1.3 Disabled

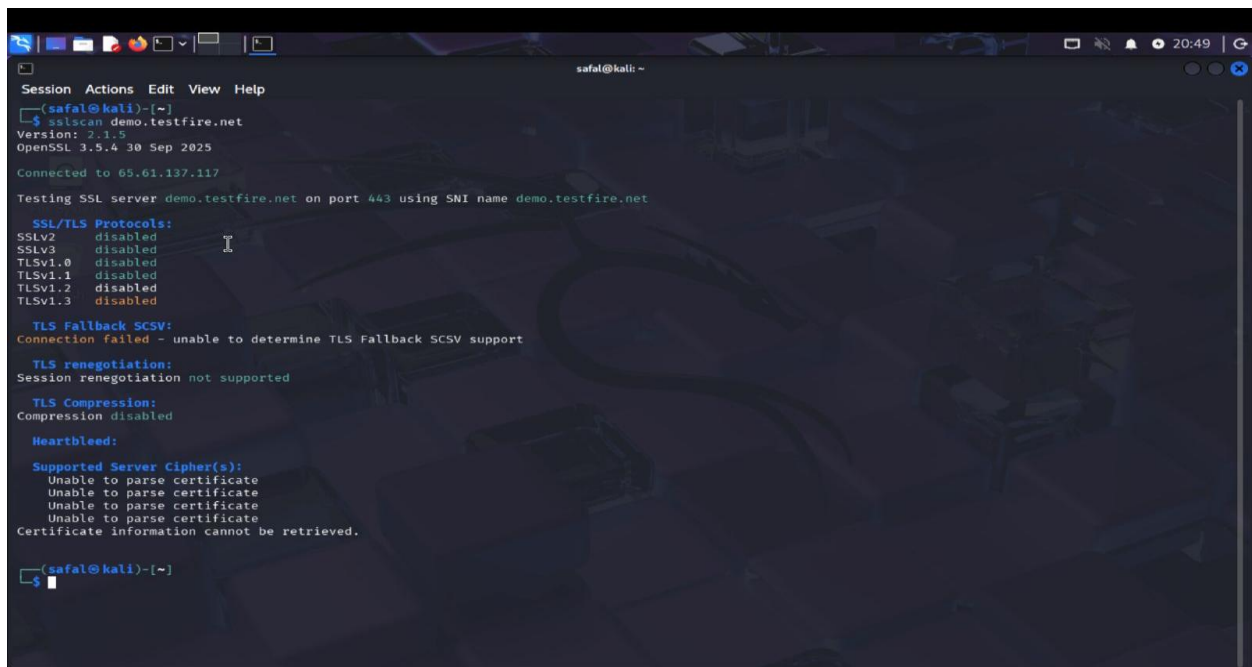
SSLv2 Disabled

SSLv3 Disabled

Key Observations

- Deprecated SSL protocols were disabled.
- TLS 1.2 support was enabled and operational.
- Cipher suite configurations require further security review.
- TLS 1.3 was not enabled.

Figure 6.1: SSLScan Output



```
Session Actions Edit View Help
(safal@kali)-[~]
└─$ sslscan demo.testfire.net
Version: 2.1.0
OpenSSL 3.5.4 30 Sep 2025
Connected to 65.61.137.117
Testing SSL server demo.testfire.net on port 443 using SNI name demo.testfire.net

SSL/TLS Protocols:
SSLv2 disabled
SSLv3 disabled
TLSv1.0 disabled
TLSv1.1 disabled
TLSv1.2 disabled
TLSv1.3 disabled

TLS Fallback SCSV:
Connection failed - unable to determine TLS Fallback SCSV support

TLS renegotiation:
Session renegotiation not supported

TLS Compression:
Compression disabled

Heartbleed:

Supported Server Cipher(s):
Unable to parse certificate
Unable to parse certificate
Unable to parse certificate
Unable to parse certificate
Certificate information cannot be retrieved.

(safal@kali)-[~]
└─$
```

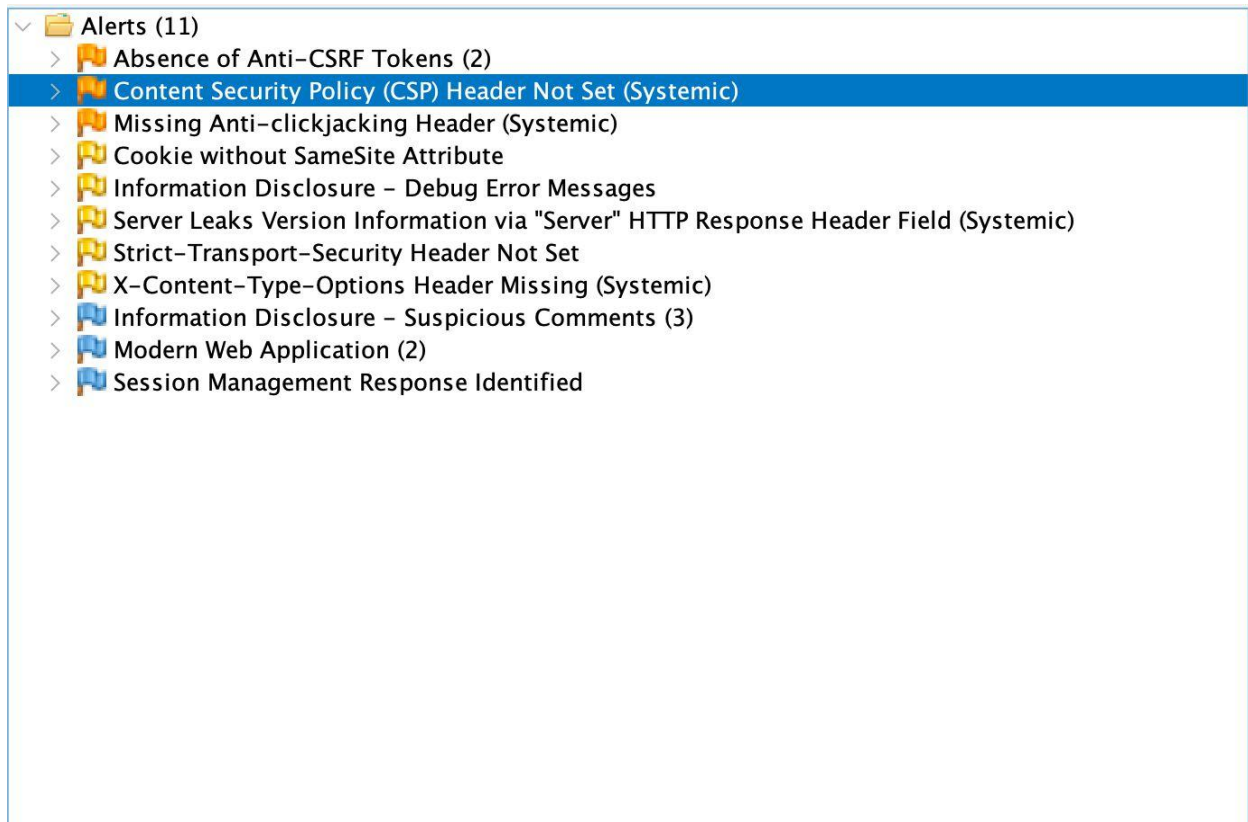

7. OWASP ZAP PASSIVE ANALYSIS

OWASP ZAP passive scanning identified several security-related misconfigurations.

Passive Scan Findings

Finding	Risk Level
Content Security Policy Header Not Set	Medium
Missing Anti-Clickjacking Header	Medium
Cookie Without SameSite Attribute	Low
Information Disclosure Through Headers	Low
Missing X-Content-Type-Options Header	Low

Figure 7.1: OWASP ZAP Dashboard



Detailed Findings

Figure 7.2: Detailed Vulnerability Findings

The screenshot displays the Burp Suite interface in Standard Mode. The top toolbar includes buttons for Quick Start, Request, Response, and Requester. The left sidebar shows the Sites tree with a selected site at `http://demo.testfire.net`. The main pane shows the details of an HTTP request to `http://demo.testfire.net/feedback.jsp`. The request headers are visible, including `Host: demo.testfire.net`, `User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:151.0) Gecko/20100101 Firefox/151.0`, and `Cookie: JSESSIONID=8F702B9575ADC5A96784C14E3E8E1DD`.

The bottom pane shows the Alerts tab with a list of 11 alerts. The selected alert is "Content Security Policy (CSP) Header Not Set" for the URL `http://demo.testfire.net/feedback.jsp`. The alert details are as follows:

- URL:** `http://demo.testfire.net/feedback.jsp`
- Risk:** Medium
- Confidence:** High
- Parameter:**
- Attack:**
- Evidence:**
- CWE ID:** 693
- WASC ID:** 15
- Source:** Passive (10038 - Content Security Policy (CSP) Header Not Set)
- Alert Reference:** 10038-1
- Input Vector:**
- Description:** Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page —
- Other Info:**
- Solution:** Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
- Reference:** <https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP>

The bottom status bar shows the current status of the tool, including the number of alerts (0) and the current status (0).

8. DETAILED VULNERABILITY FINDINGS

Finding 1: Missing Content Security Policy (CSP)

Severity

Medium

Description

The application does not implement a Content-Security-Policy (CSP) header, increasing the risk of Cross-Site Scripting (XSS) attacks.

Potential Impact

Attackers may inject and execute malicious scripts within user sessions.

Recommendation

Implement a restrictive Content-Security-Policy header to control trusted content sources.

Finding 2: Missing X-Frame-Options Header

Severity

Medium

Description

The application does not restrict iframe embedding.

Potential Impact

Users may become vulnerable to clickjacking attacks.

Recommendation

Configure the X-Frame-Options header using either:

- DENY
- SAMEORIGIN

Finding 3: Cookie Without SameSite Attribute

Severity

Low

Description

Session cookies do not include the SameSite attribute.

Potential Impact

Potential exposure to Cross-Site Request Forgery (CSRF) attacks.

Recommendation

Configure cookies with:

- SameSite=Strict
- SameSite=Lax

as appropriate for application functionality.

9. RISK CLASSIFICATION MATRIX

Finding	Severity	OWASP Category
Missing CSP Header	Medium	A05 – Security Misconfiguration
Missing X-Frame-Options Header	Medium	A05 – Security Misconfiguration
Missing HSTS Header	Medium	A05 – Security Misconfiguration
Cookie Without SameSite Attribute	Low	A07 – Identification and Authentication Failures
Information Disclosure	Low	A05 – Security Misconfiguration

10. SECURITY POSTURE ASSESSMENT

Security Evaluation Scores

Assessment Domain	Score
-------------------	-------

HTTP Security Headers	3/10
-----------------------	------

Cookie Security	4/10
-----------------	------

SSL/TLS Configuration	6/10
-----------------------	------

Information Exposure	4/10
----------------------	------

Client-Side Security	4/10
----------------------	------

Overall Security Posture Score

4/10 – MEDIUM RISK

The assessment identified multiple security misconfigurations that should be addressed before deployment within a production environment.

11. REMEDIATION RECOMMENDATIONS

Priority 1 – Immediate Actions

- Implement missing HTTP security headers.
- Configure Content Security Policy (CSP).
- Configure X-Frame-Options protection.
- Remove unnecessary server banner disclosures.

Priority 2 – Short-Term Actions

- Configure Secure, HttpOnly, and SameSite cookie attributes.
- Enforce HTTPS across all application components.
- Implement HSTS headers.

Priority 3 – Medium-Term Actions

- Harden SSL/TLS configurations.
- Enable TLS 1.3 support where possible.
- Remove weak or deprecated cipher suites.

12. CONCLUSION

The passive vulnerability assessment of Altoro Mutual identified several security misconfigurations involving HTTP security headers, SSL/TLS configurations, cookie security settings, and information disclosure mechanisms.

The assessment was performed using strictly passive and non-intrusive techniques, ensuring that no exploitation attempts or destructive testing activities occurred.

The findings demonstrate common security weaknesses frequently encountered in web applications and provide valuable educational insight into secure application deployment and defensive security practices.

13. DISCLAIMER

This assessment was conducted solely for educational and internship purposes using passive and non-intrusive security testing techniques.

No exploitation attempts, unauthorized access, or destructive testing activities were performed during the assessment.

Altoro Mutual is an intentionally vulnerable web application designed for cybersecurity education and training.

This report is intended exclusively for educational demonstration, internship evaluation, academic submission, and professional portfolio purposes.